

Utilização do Sistema de Autorizações

Índice

1. Enquadramento	1
2. Descrição do serviço	1
3. Visão geral e atores.....	2
Fluxo de funcionamento	2
4. Especificação técnica dos serviços a usar pelo consumidor	2
5. Pedido de Autorização	3
Endpoints	3
Requisitos de header	3
5.1 Pedido	4
Exemplo de pedido	5
5.2 Resposta.....	5
Exemplo de resposta.....	5
Continuação do fluxo.....	6
ReplyBack.....	6
6. Obtenção de Informação	7
Endpoints	7
6.1 Pedido	7
6.2 Resposta.....	7
7. Ferramentas de apoio.....	9

1. Enquadramento

No contexto da modernização administrativa, da desmaterialização e da melhoria contínua dos processos da Administração Pública (AP), com foco no serviço prestado pela AP ao seu cliente — o Cidadão/Empresa —, foi definido e implementado o Sistema de Autorizações.

A Medida 22 do Programa Simplex 2019 preconiza um “mecanismo que permite aos cidadãos e às empresas a monitorização do acesso aos seus dados pessoais e empresariais, nomeadamente com funcionalidades de criação, visualização e gestão de autorizações de acesso”.

Neste âmbito, a Agência para a Modernização Administrativa, I.P. (AMA), desenvolveu uma plataforma de gestão de acessos públicos que permite às entidades aderentes obter informação presente nos sistemas públicos via web services REST, mediante autorização do cidadão. Esta plataforma, denominada Sistema de Autorizações (SA), disponibiliza uma app onde o cidadão pode gerir as autorizações que concede às entidades para acesso aos seus dados.

O presente documento identifica as normas de integração que devem ser seguidas para, através dos web services disponíveis, obter a informação com o consentimento do cidadão.

2. Descrição do serviço

Nesta secção descreve-se o serviço e identificam-se os intervenientes, sejam utilizadores ou entidades externas. Pretende-se, assim, apresentar uma visão simples e resumida dos requisitos funcionais.

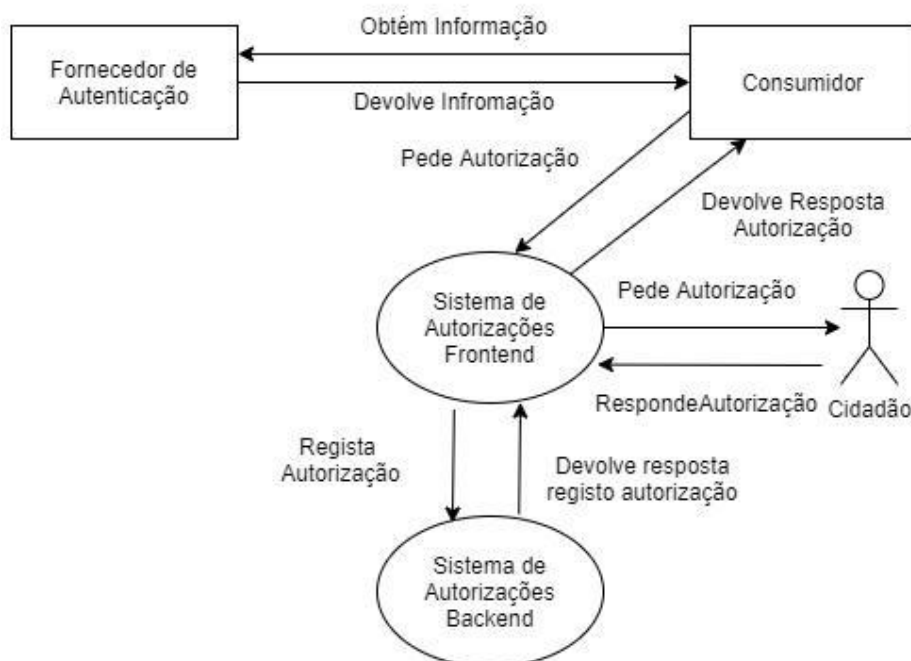


Figura 1 — Fluxo funcional entre Consumidor, cidadão, Sistema de Autorizações e Fornecedor de Autenticação.

3. Visão geral e atores

O ecossistema baseia-se na Medida 22 do Programa Simplex 2019, focando-se na transparência e no controlo dos dados pessoais.

Ator	Função
Consumidor	Entidade que solicita o acesso aos atributos do cidadão.
Cidadão	Titular dos dados que gere autorizações via app/frontend SA.
Sistema de Autorizações (SA)	Gere o ciclo de vida da autorização, incluindo frontend e backend.
Fornecedor de Autenticação (FA)	Valida tokens e fornece os dados finais (atributos).

3.1. Fluxo de funcionamento

O processo de integração divide-se em três grandes momentos técnicos:

1. **Pedido de Autorização:** o Consumidor invoca o SA. Se não existir autorização prévia, o cidadão é notificado para aceitar ou rejeitar;
2. **Aceitação e reply back:** o utilizador responde à autorização e é despoletado o envio automático do reply back com o resultado;
3. **Obtenção de Informação:** após a aceitação, o Consumidor utiliza o token recebido para obter os dados junto do Fornecedor de Autenticação (FA).

4. Especificação técnica dos serviços a usar pelo consumidor

O consumidor necessita de ser um cliente JWT registado no FA (Fornecedor de Autenticação). Para tal, deve possuir um certificado privado, utilizado para gerar o token a enviar no header Authorization do serviço abaixo. O certificado público tem de estar registado no FA.

O consumidor necessita ainda de requerer a autorização, invocando o SA, e de obter os dados, invocando o Fornecedor de Autenticação.

Para efeitos de teste, usar:

consumer: 9103896380155753844

Authorization Token:

```
eyJhbGciOiJIUzI1NiIsImtpZCI6IkkRCQzY3ODlFRlRFRDZDNkRGMEI5NEZGQTJBQjFBNzk1NzZmRDcwRDhFNTYiLCJ4NXQiOiJZQmhlX0NsQWJjaURLdnRhd2IzZDU56ejFtQ28iLCJ0eXAiOiJKV1QiLCJ0eXkiOiJkxMDM4OTYzODAxNTU3NTM4NDQ1LCJleHBpcnVzX2luIjoimZlNTY5MjY1LCJpYXQiOiJlMjY1LWk3na04g9810JVQGI6DBL4T4SPLLMLjYuiXC64nPG5u4Cn8K-q2A6qAF-q0gZ4TTrYN4C18diiDthrFINGRCg5CIGViyp90Ar8pPG4oPbQykatdjFfYeXiliPlm60tMz8G7tfBktcnJk-1Bo2h0VBf-_08aHNJKd0Cdylw4A0jU2ymQ6FwSyH3v0jkzwd08KBYBR8WcT6USaIOYdxVJAmmX5pZcZjRUCjeMQ1Wq8YuNdzvJBHi1gX5257kuCu-uq4gfTmaI6gjhBlwvBnSJptC-mB0TSDFGx3LPbQdD7103a9JBuqg3usw_0M2DMws15sjiH_35B350ntc4dJGSRpmOxL0a0VMmpD5oJ12RH6oZpTRSAMENbj0nfNjwVHMBqD4xBogkbgboGrCPha8p4cKp10mzXvt1rv26F0yagmMnB3AAhRr7tQ0Ny6t7E6hsf1rLmoXVkrAXWr4YMNWQyVruE9e
```

5. Pedido de Autorização

Este serviço regista a intenção de aceder aos dados e despoleta a notificação ao cidadão.

Endpoints

- **PPR:**
<https://ppr.autenticacao.gov.pt/AuthorizationSystemFrontend/authorizationsystem/frontend/request/authorization>
- **PRD:**
<https://www.autenticacao.gov.pt/AuthorizationSystemFrontend/authorizationsystem/frontend/request/authorization>

Requisitos de header

É obrigatório o envio de um Bearer Token JWT no header como “Authorization”. Este token deve ser gerado com o certificado privado da entidade registada no FA.

5.1 Pedido

Descrição:	“Pedido Autorização” – Serviço de pedido de autorizações				
Observações:	Nem o campo Owner nem o campo ForeignOwner são obrigatórios, mas um deles tem obrigatoriamente de estar preenchido (e apenas um). O mesmo se aplica aos campos Consumer, ConsumerNIF e ForeignConsumer (apenas um deve estar preenchido). Caso o campo ConsumerNIF seja preenchido, é necessário que os campos ConsumerEntityName e Employee também sejam preenchidos, uma vez que, nesse caso, é registrada uma nova entidade. De momento, este fluxo não está a ser utilizado (utilizando o campo ConsumerNIF).				
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	Owner (NIC)	String	8	Não*	0 1
2	ForeignOwner	ForeignCitizenId	-	Não*	0 1
*	DocumentType	String	-	*Sim	1
*	CountryCode	String	-	*Sim	1
*	DocumentId	String	-	*Sim	1
3	Consumer	String	8	Não	0 1
4	ForeignConsumer	ForeignCitizenId	-	Não	0 1
5	ConsumerNIF	String	9	Não	0 1
5	InformationType	String	-	Sim	1
6	ConsumerType	SubjectTypeEnum	-	Sim	1
7	Validity	String	16	Não	0 1
8	AdditionalInfo	List<AdditionalInfo>	-	Não	0 1
9	RequestDescription	String	45	Não	0 1
10	OwnerName	CitizenName	-	Não	0 1
11	ConsumerName	CitizenName	-	Não	0 1
12	ChannelCode	String	45	Sim	1
13	ReplyTo	String	200	Não	0 1
14	ReplyDeadline	String	16	Sim	1
15	LanguageDescription	String	-	Não	0 1
16	AttributeList	List<String>	-	Não*	0 1
17	Group	String	10	Não	0 1
18	Employee	Employee	-	Não*	0 1
*	Nic	String	8	*Sim	1
*	CitizenName	CitizenName	-	*Sim	1
**	FirstName	String	45	*Sim	1
**	LastName	String	45	*Sim	1
19	ConsumerEntityName	String	-	Não*	0 1
20	HasPreview	Boolean	-	Não	0 1
21	ExpiresIn	Long	-	Não	0 1
22	AppType**	String	45	Não	0 1

Nota crítica: deve preencher exatamente um campo entre Owner/ForeignOwner e exatamente um campo entre Consumer/ConsumerNIF/ForeignConsumer. Se utilizar ConsumerNIF, os campos ConsumerEntityName e Employee passam a ser obrigatórios.

Exemplo de pedido

```
{
  "owner": "88888888",
  "consumer": "9103896380155753844",
  "informationType": "JWT",
  "consumerType": "ENTITY",
  "replyDeadline": "2030-05-15 00:00",
  "validity": "2030-12-17 00:00",
  "replyTo": " http://url/para/retornar/resposta",
  "requestDescription": "olaaaaaolaaaaaaa",
  "channelCode": "a639c28a-c680-4706-ac74-404fff9eefde",
  "attributeList": [
    "http://interop.gov.pt/MDC/Cidadao/NIC",
    "http://interop.gov.pt/MDC/Cidadao/NomeCompleto",
    "http://interop.gov.pt/MDC/Cidadao/NIF"
  ]
}
```

Os parâmetros assinalados a amarelo são os necessários alterar para realizar testes.

NOTA: O replyTo só pode ser para o port 80, se for outro irá falhar.

5.2 Resposta

Descrição:	"Comunicação da resposta do cidadão" – Resposta ao serviço de confirmação do pedido de autorizações				
Observações:					
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	Result	Result	-	Sim	1
2	RequestNumber	String	36	Sim	1
3	Validity	String	-	Não	0 1
4	jwt	String	-	Não	0 1

Descrição:	Result – Representação do resultado				
Observações:					
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	Code	String	25	Sim	1
2	Description	String	70	Sim	1

Exemplo de resposta

O sistema devolve um requestNumber (para rastreio) e a informação de que a autorização está a aguardar aprovação.

```
{
  "result": {
    "code": "PENDING",
    "description": "Autorização está a ser validada"
  },
  "requestNumber": "ed448ac2-c85d-4fca-b6c4-695730e4c538"
}
```

Continuação do fluxo

Depois disso, o cidadão necessita de aceder à app gov.pt do ambiente correspondente e responder à autorização. Só após a aceitação se deve avançar para o passo seguinte.

Ao aceitar ou negar a autorização, é despoletado o método `replyBack` da classe `ChannelInvoker`, de forma a notificar a entidade que pediu a autorização de que a mesma foi aceite ou rejeitada.

Nesse `replyBack` é devolvida a resposta a indicar se a autorização foi rejeitada ou aceite com sucesso, bem como o JWT necessário para pedir os dados autorizados ao FA.

ReplyBack

```
{
  "result": {
    "code": "AUTH_ACCEPTED",
    "description": "Autorização aceite pelo titular"
  },
  "requestNumber": "ad987db9-5104-49f7-885c-cb0f3951bdab",
  "validity": "2030-12-17 00:00",
  "jwt": <JWT_TOKEN>
}
```


6. Obtenção de Informação

Após o cidadão aceitar o pedido, este serviço permite recuperar os dados reais, como o NIF, o nome, entre outros.

Endpoints

- PPR: <https://preprod.autenticacao.gov.pt/OAuthResourceServer/Service/ResourceJWT.svc/resourceJWT>
- PRD: <https://autenticacao.gov.pt/OAuthResourceServer/Service/ResourceJWT.svc/resourceJWT>

6.1 Pedido

Descrição:	Serviço de obtenção de informação				
Observações:					
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	Token	String	-	Sim	1
2	AttributesName	List<String>	-	Sim	1

```
{
  "token": <JWT_TOKEN_RECEBIDO_NO_REPLY_BACK>,
  "attributesName": [
    "http://interop.gov.pt/MDC/Cidadao/NomeCompleto",
    "http://interop.gov.pt/MDC/Cidadao/NIC",
    "http://interop.gov.pt/MDC/Cidadao/NIF"
  ]
}
```

6.2 Resposta

Descrição:	Serviço de obtenção de informação				
Observações:	Os atributos são enviados dentro das claims do jsonWebToken.				
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	JsonWebToken	String	-	Sim	1
2	ProcessId	String	-	Não	0 1
3	Result	Result	-	Sim	1

Descrição:	Result – Representação do resultado				
Observações:					
ID	Campo (descrição)	Tipos de dados	Tamanho	Obrigatório	Ocorrências
1	Code	String	25	Sim	1
2	Message	String	70	Sim	1

Os dados solicitados vêm codificados dentro das claims do jsonWebToken devolvido.

```
{
  "jsonWebToken": <JWT_TOKEN>,
  "processId": null,
  "result": {
    "code": "200",
    "message": "JWT token created, attributes received"
  }
}
```

Utilização do Sistema de Autorizações

Agora ao receber o "jsonWebToken", pegamos no mesmo e vamos ao <https://www.jwt.io/> e introduzimos para extrair a informação pretendida. Abaixo pode ser visto um exemplo:

Paste a JWT below that you'd like to decode, validate, and verify.

Generate example

Select signing algorithm

Encoded Token

☐ Enable auto-focus

>. JSON Web Token (JWT)

```
eyJhbGciOiJSUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vaW50ZXJvcC5nb3YucHQvTURDL0NpZGFkYW8vTkIdIjoimZA4NDU5NjcilCjodHRwOi8vaW50ZXJvcC5nb3YucHQvTURDL0NpZGFkYW8vTm9rZlVub3B5ZXRvIjoiaS5Do28gRGlvZ28gQ29zdGEiLCJodHRwOi8vaW50ZXJvcC5nb3YucHQvTURDL0NpZGFkYW8vTkIdIjoimjQwNDAxMzIiIiwiaXhwIjoixNzgxMjYwZWUwFQ.O0rQ-mrx5gY9iniOjJVsc9smoNugs6tursn02uIgLnkkpM1msyxD0pjly7Iha7QovlrXQhbXR25XMGRUXG_S5VBBDjtKzGJ-J9vpProvxpNVz7hb1QLs5o12GL9hRobQ-2VOyaKbyJpqJf7BB_Wb2yeymxzDkB-s_amLFtpG2ouI0wahAjf9gJxvdw7ZBIJI55PbMI9UrtWnvFDkdpp6ljHdYNqmM0z9Vfzfml14rA6wejiAkZXKEiQTxlVKBDwZ1A8UCjN_DFGIx92-ZJWKN5wyTiCF9m3mb1qFuayRtICsYrGwOn3iZlFSyb-sxn_cshAPgJAghmpHcS_yCIAikIQ
```

☒ Valid JWT

Decoded Header

JSON Claims Breakdown

```
{  "alg": "RS512",  "typ": "JWT"}
```

Decoded Payload

JSON Claims Breakdown

```
{  "http://interop.gov.pt/MDC/Cidadao/NIC": "30845967",  "http://interop.gov.pt/MDC/Cidadao/NomeCompleto": "Jo\u00e3o Diogo Costa",  "http://interop.gov.pt/MDC/Cidadao/NIF": "240401328",  "exp": 1781260350}
```

JWT Signature Verification (Optional)

Enter the public key used to sign the JWT below:

Public Key Format

PEM

>. Public Key

Public Key in SPKI, PKCS #1, X.509 Certificate, or JWK string format.

Unable to automatically download public key from JWKS. Please enter public key manually to continue.

7. Ferramentas de apoio

- **Validação de tokens:** para inspecionar o conteúdo dos JWTs recebidos (especialmente a resposta final do FA), utilize <https://www.jwt.io/>
- **Certificados:** garanta que o seu certificado público está corretamente registrado no Fornecedor de Autenticação (FA), para que o header Authorization seja validado com sucesso.